# ACME GLOBAL ENTERPRISE ? AI SECURITY & DATA GOVERNANCE POLICY 2025

## SECTION 1: PURPOSE AND ORGANIZATIONAL SCOPE

This Data Governance and Artificial Intelligence Security Policy defines mandatory architectural and procedural guardrails for all AI/ML workloads, Large Language Models (LLMs), and Retrieval-Augmented Generation (RAG) deployments across Acme Global Enterprise systems.

### 1.1 CLASSIFICATION OF AI SYSTEMS

All AI systems deployed within Acme infrastructure are categorized into three distinct operational risk tiers:

- Tier-1 (High Risk / Regulatory): Systems interacting directly with customer Personally Identifiable Information (PII), automated credit decisions, or medical and clinical records.
- Tier-2 (Internal Operational / RAG): Knowledge retrieval engines, internal code generation assistants, and customer support triage tools grounded in enterprise knowledge bases.
- Tier-3 (Low Risk / Exploratory): Offline sandboxed research models with zero access to live enterprise databases or intellectual property.

### 1.2 MANDATORY ARCHITECTURAL CONTROLS

Every Tier-1 and Tier-2 deployment must implement dual-custody access controls, immutable logging of prompt and retrieval trajectories, and cryptographic verification of all upstream vector database indices. Under no circumstances may raw customer proprietary data be ingested into third-party public models without explicit encryption and tenant isolation.

SECTION 2: DATA PRIVACY, PII REDACTION & RETENTION LIMITS

2.1 REAL-TIME PII REDACTION PROTOCOLS

Prior to document ingestion and vectorization, all unstructured documents (PDF, DOCX, TXT) must pass through an automated Named Entity Recognition (NER) pipeline. The pipeline must redact or tokenize:

- Social Security Numbers (SSNs), National Identity Numbers, and Passport Identifiers.
- Primary Account Numbers (PANs), bank routing codes, and cryptographic wallet keys.
- Protected Health Information (PHI) including diagnostic notes, patient IDs, and insurance claim codes.

2.2 DATA RETENTION AND PURGING SLAs

- Ephemeral Chat Sessions: Transient conversation memory buffers must be cryptographically shredded within twenty-four (24) hours of session inactivity.
- Knowledge Base Vector Stores: Embedded document chunks remain active until explicit administrative decommission. Upon receipt of a formal GDPR/CCPA 'Right to Erasure' request, document chunks and associated HNSW vector embeddings must be purged within thirty (30) calendar days.
- Audit & Retrieval Traces: Retrieval traces, including cosine similarity scores, reranker confidence levels, and user feedback ratings, must be retained in cold storage for seven (7) years to satisfy regulatory audits.

## SECTION 3: GROUNDED RETRIEVAL STANDARDS & HALLUCINATION AUDITING

### 3.1 HYBRID RETRIEVAL AND RERANKING THRESHOLDS

Enterprise RAG architectures must implement a multi-stage retrieval pipeline rather than naive vector search:

- Dual-Path Retrieval: A hybrid fusion of Dense Vector Search (cosine similarity via pgvector HNSW index) and Lexical Sparse Search (PostgreSQL TSVECTOR with GIN indexing) combined using Reciprocal Rank Fusion (RRF, k=60).
- Cross-Encoder Verification: Candidate passages retrieved from hybrid search must be reranked by a secondary cross-encoder scoring model. Passages failing a normalized relevance score threshold of 0.70 must be dropped from final LLM context.

### 3.2 FAITHFULNESS AND FACTUAL GROUNDING BENCHMARKS

All generative responses produced by enterprise RAG pipelines are audited against automated evaluation metrics:

- Faithfulness Metric: Minimum acceptable threshold is 95.0% factual alignment with retrieved context chunks.
- Answer Relevancy: Minimum acceptable score is 90.0% semantic correspondence to the user query.
- Context Precision: Must exceed 85.0% to prevent context stuffing and token budget exhaustion.

Any automated benchmark suite run reporting Faithfulness below 92.0% triggers an immediate Sev-2 engineering alert and initiates algorithmic rollback.

SECTION 4: INCIDENT RESPONSE, EXFILTRATION PROTOCOLS & ESCALATION MATRIX

4.1 UNAUTHORIZED DATA EXFILTRATION CONTROLS
If an adversarial prompt injection, jailbreak attempt, or unauthorized data extraction vector is detected:
- The active API session must be immediately terminated.
- The originating IP address and user token must be quarantined for dynamic forensic review.
- The incident must be logged with an SHA-256 fingerprint in the enterprise security SIEM within 120 seconds.

4.2 INCIDENT SEVERITY AND ESCALATION TIMELINES
- Severity 1 (Critical): Active exfiltration of Tier-1 customer records or vector index corruption. Immediate response within 15 minutes; executive notification within 1 hour.
- Severity 2 (High): RAG benchmark faithfulness degradation below 92% or cross-tenant query bleed. Response required within 1 hour.
- Severity 3 (Medium): Transient API rate limiting or document ingestion queue latency > 5 minutes. Response within 4 business hours.

4.3 EMERGENCY CONTACTS AND OVERSIGHT COMMITTEE
- Enterprise AI Security Operations Center: soc-ai@acme-enterprise.ai | Hotline: +1 (800) 555-0199
- Chief Data Protection Officer: dpo@acme-enterprise.ai
- Lead AI Retrieval Engineer: sarah.chen@enterprise.ai